Vulnerability Assessment & Penetration Testing (VAPT) Report

Title Page

Vulnerability Assessment & Penetration Testing (VAPT)
Web Application Security Assessment
Internship Project
Tamheed – Intern – Cyber Security
Date: [Insert Date]

---

1. Introduction

-

VAPT is the process of identifying and exploiting vulnerabilities in web applications or systems.

Purpose: To assess security risks and demonstrate penetration testing techniques in a controlled lab environment.

-

---

2. Objectives

-

Identify vulnerabilities in DVWA.

Exploit common web security flaws.

Document findings with screenshots.

Recommend mitigation strategies.

-

---

3. Tools Used

•

Ubuntu Linux

Docker

Nmap (Network scanning)

OWASP ZAP (Spider & Vulnerability Scanner)

DVWA (Target Web Application)

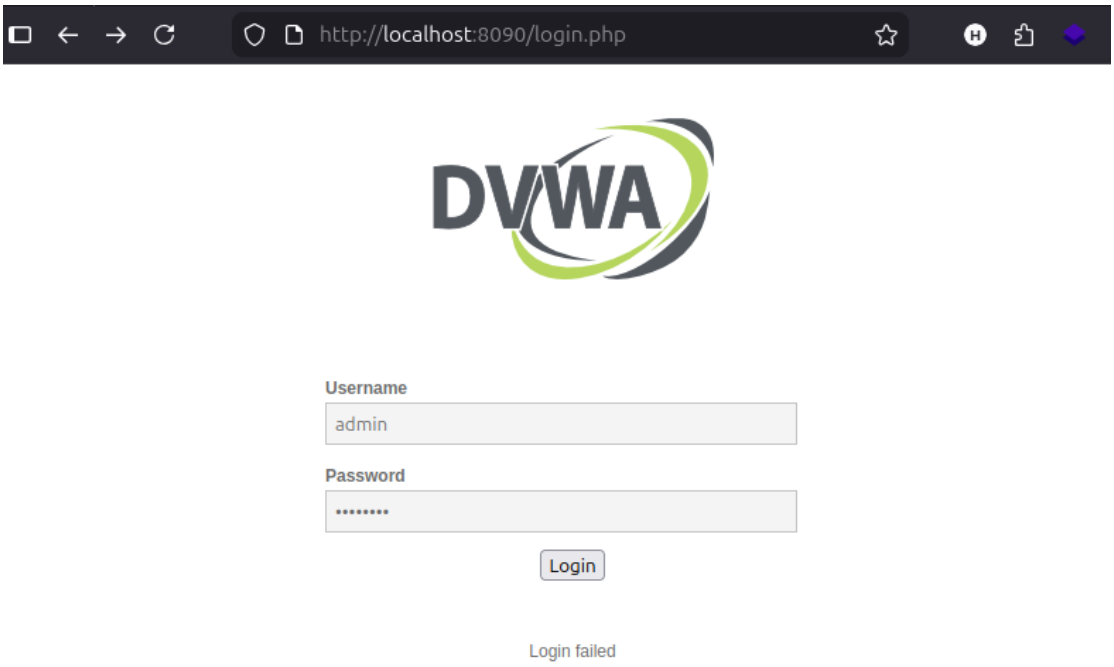
•

---

4. Lab Setup

•

DVWA running locally in Docker container.



Browser configured for ZAP proxy.

Localhost used as testing environment.

- Home
- Instructions
- Setup / Reset DB

- Brute Force
- Command Injection
- CSRF
- File Inclusion
- File Upload
- Insecure CAPTCHA
- SQL Injection
- SQL Injection (Blind)
- Weak Session IDs
- XSS (DOM)
- XSS (Reflected)
- XSS (Stored)
- CSP Bypass
- JavaScript

- DVWA Security
- PHP Info
- About

- Logout

Welcome to Damn Vulnerable Web Application!

Damn Vulnerable Web Application (DVWA) is a PHP/MySQL web application that is damn vulnerable. Its main goal is to be an aid for security professionals to test their skills and tools in a legal environment, help web developers better understand the processes of securing web applications and to aid both students & teachers to learn about web application security in a controlled class room environment.

The aim of DVWA is to **practice some of the most common web vulnerabilities**, with **various levels of difficultly**, with a simple straightforward interface.

General Instructions

It is up to the user how they approach DVWA. Either by working through every module at a fixed level, or selecting any module and working up to reach the highest level they can before moving onto the next one. There is not a fixed object to complete a module; however users should feel that they have successfully exploited the system as best as they possible could by using that particular vulnerability.

Please note, there are **both documented and undocumented vulnerability** with this software. This is intentional. You are encouraged to try and discover as many issues as possible.

DVWA also includes a Web Application Firewall (WAF), PHPIDS, which can be enabled at any stage to further increase the difficulty. This will demonstrate how adding another layer of security may block certain malicious actions. Note, there are also various public methods at bypassing these protections (so this can be seen as an extension for more advanced users)!

There is a help button at the bottom of each page, which allows you to view hints & tips for that vulnerability. There are also additional links for further background reading, which relates to that security issue.

WARNING!

Damn Vulnerable Web Application is damn vulnerable! **Do not upload it to your hosting provider's public html folder or any Internet facing servers**, as they will be compromised. It is recommend using a virtual machine (such as VirtualBox or VMware), which is set to NAT networking mode. Inside a guest machine, you can downloading and install XAMPP for the web server and database.

Disclaimer

We do not take responsibility for the way in which any one uses this application (DVWA). We have made the purposes of the application clear and it should not be used maliciously. We have given warnings and taken measures to prevent users from installing DVWA on to live web servers. If your web server is compromised via an installation of DVWA it is not our responsibility it is the responsibility of the person/s who uploaded and installed it.

More Training Resources

DVWA aims to cover the most commonly seen vulnerabilities found in today's web applications. However there are plenty of other issues with web applications. Should you wish to explore any additional attack vectors, or want more difficult challenges, you may wish to look into the following other projects:

Screenshots and evidence captured for all vulnerabilities.

-

---

5. Methodology

1.

Information Gathering:

2.

Vulnerability Scanning:

3.

Exploitation:

4.

Documentation:

---

6. Vulnerabilities Found

6.1 SQL Injection

-

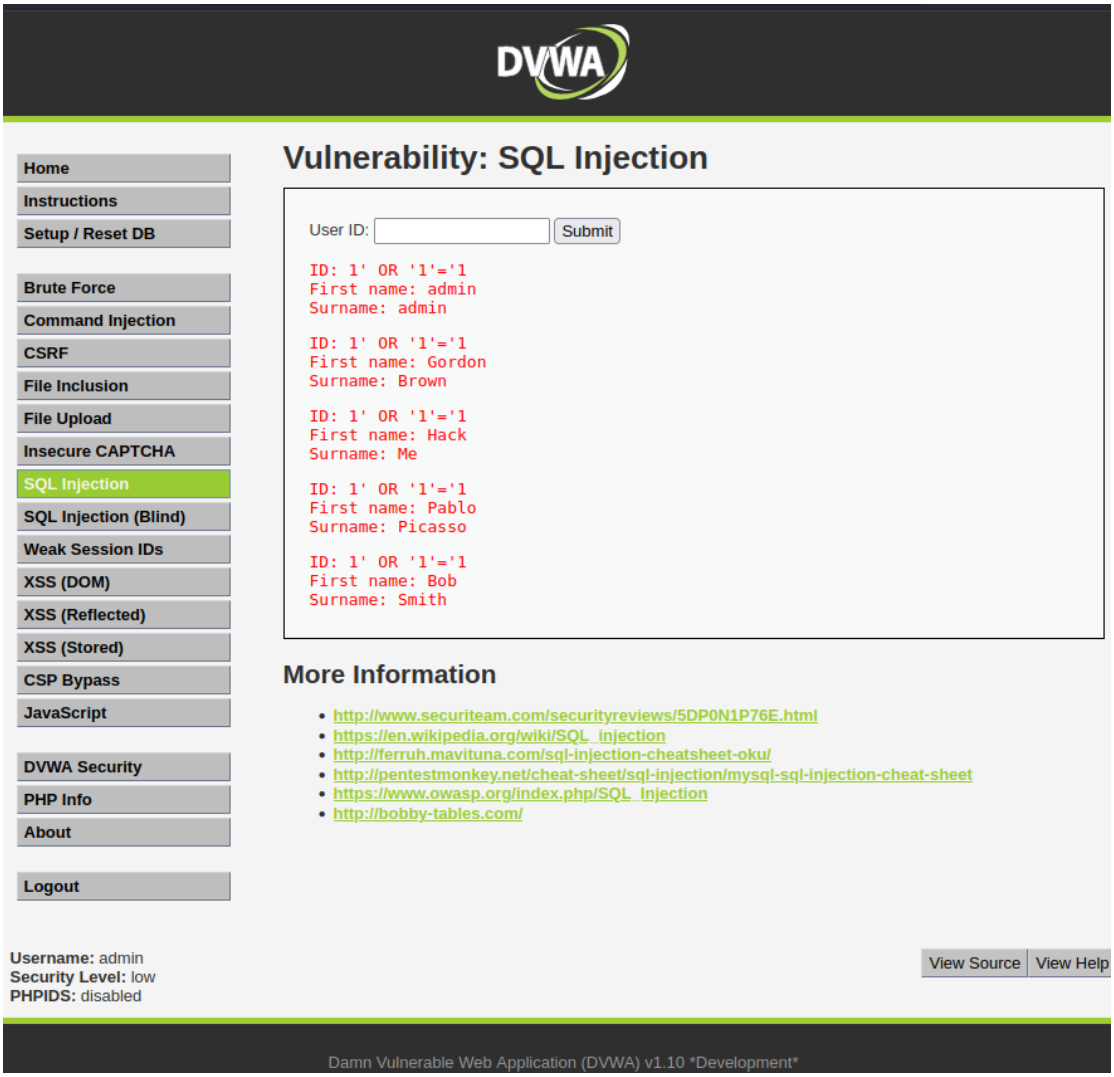
Severity: High

Payload: `1' OR '1'='1`

Impact: Authentication bypass, data leakage

Mitigation: Prepared statements, input validation

Screenshot:



-

6.2 Cross Site Scripting (XSS)

-

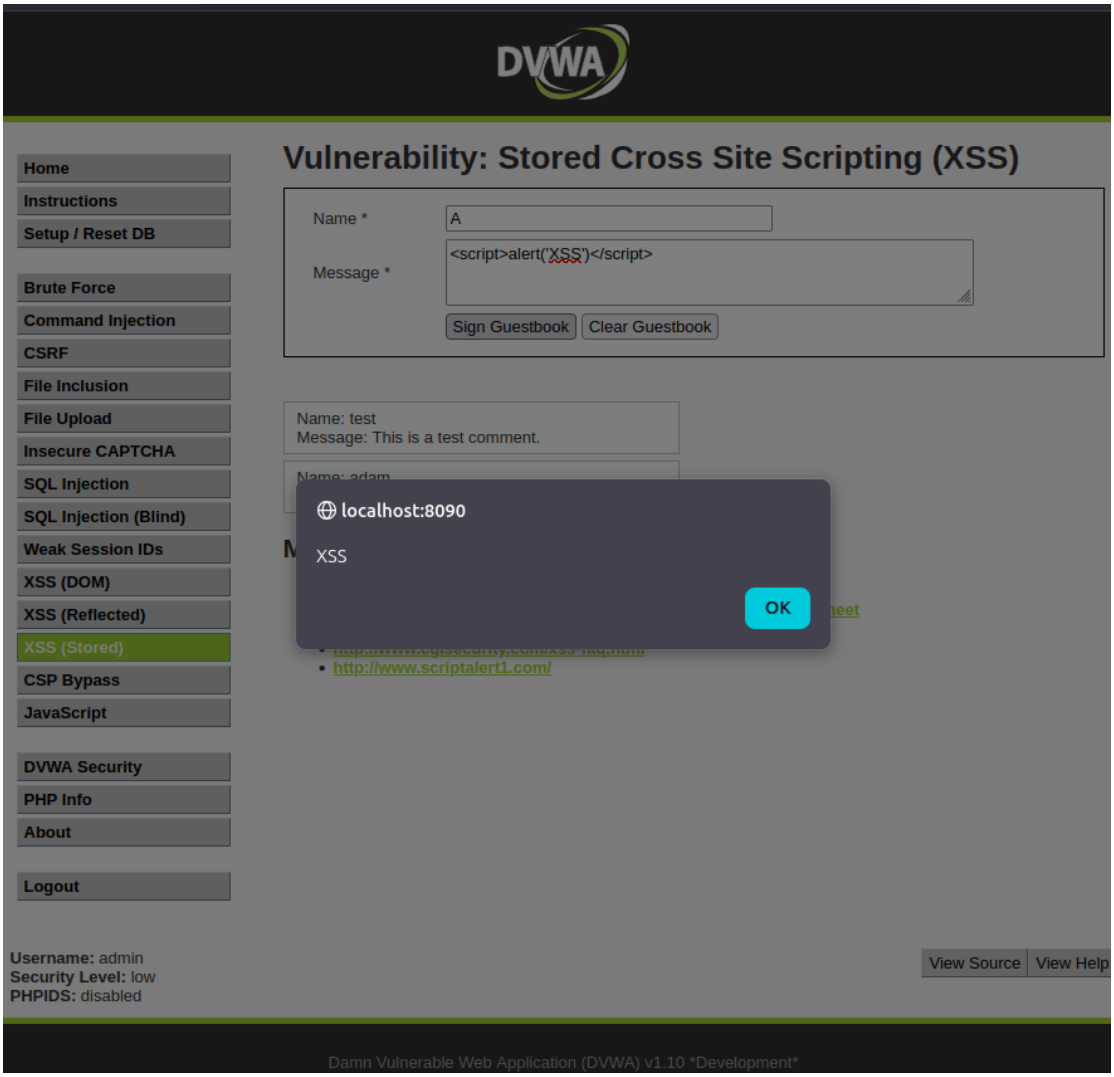
Severity: Medium

Payload: `<script>alert('XSS')</script>`

Impact: Session hijacking, credential theft

Mitigation: Input validation, CSP

Screenshot:



-

6.3 Command Injection

-

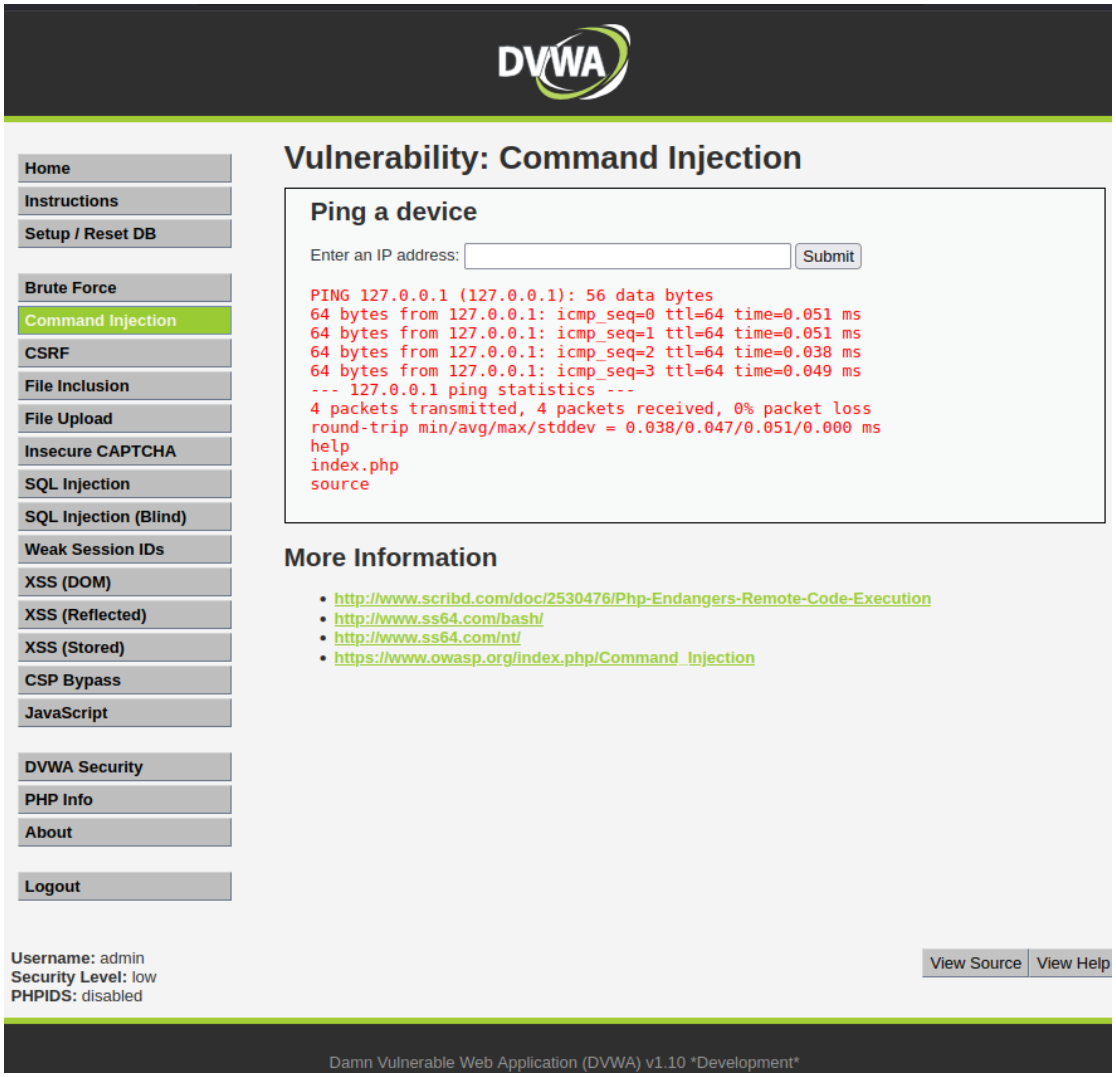
Severity: High

Payload: `127.0.0.1; ls`

Impact: Remote command execution

Mitigation: Sanitize user inputs

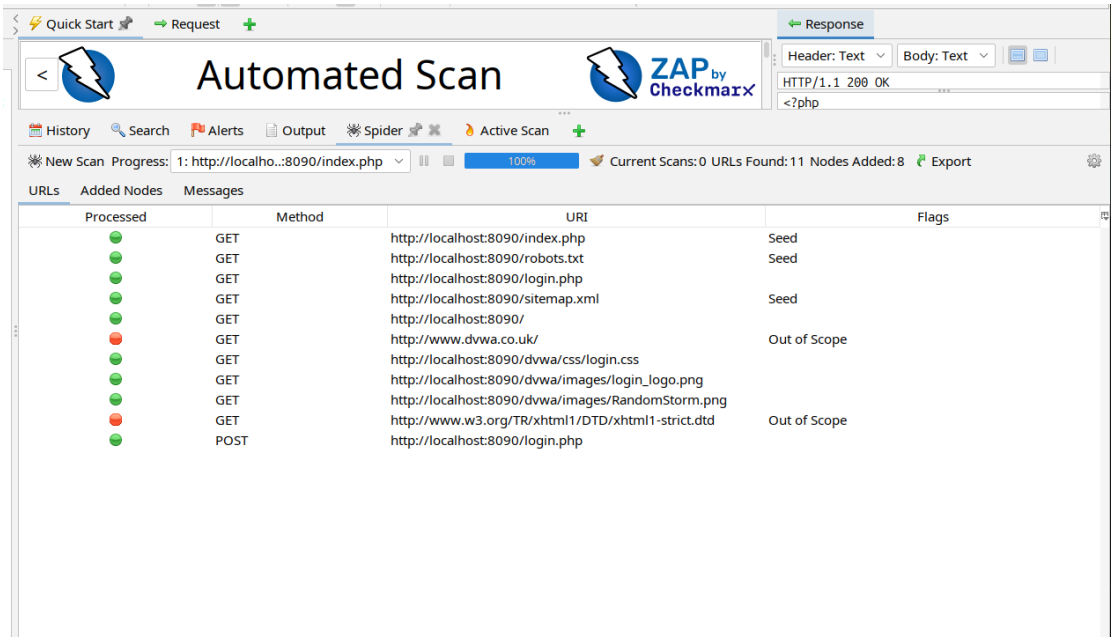
Screenshot:

- 

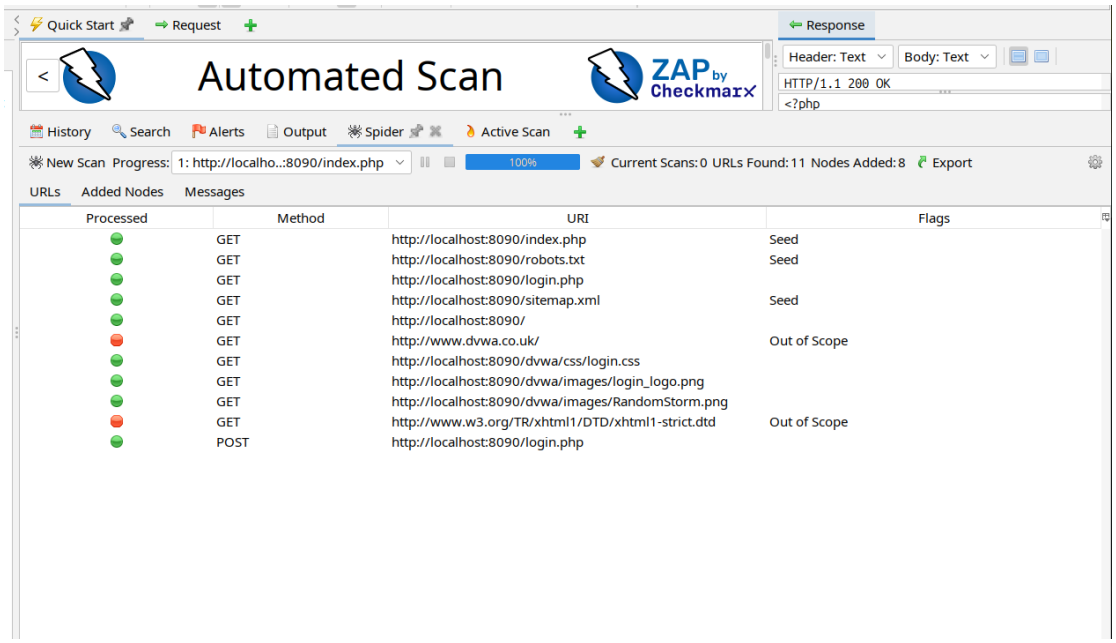
6.4 OWASP ZAP Spider & Alerts

-

Spider Scan Screenshot:



Alerts Screenshot:

- 

Description: Automatic scanning to identify reachable pages and vulnerabilities.

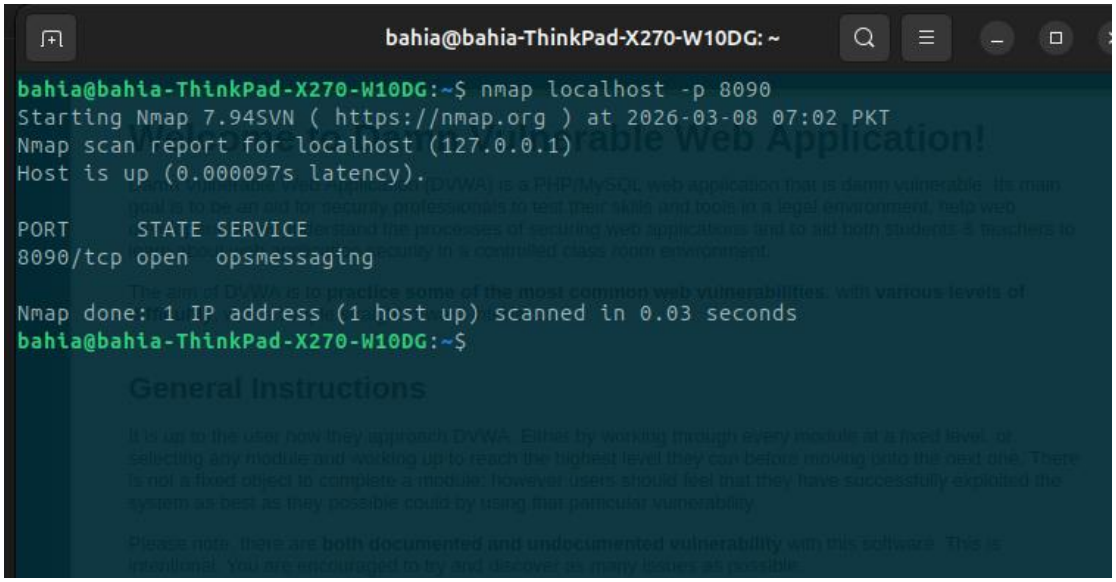
-

6.5 Nmap Scan

-

Description: Identified open ports and services on localhost.

Screenshot:

- 

---

7. Risk Assessment

Vulnerability	Risk Level
SQL Injection	High
Command Injection	High
XSS	Medium

---

8. Conclusion

-

The VAPT process identified and exploited key vulnerabilities in DVWA.

Regular testing, secure coding, and proper input validation can reduce risks.

-

---

9. References

-

[OWASP SQL Injection]

OWASP XSS

DVWA GitHub

OWASP ZAP

-

Tamheed – Intern – Cyber Security